

Due-Diligence Report: live_Portfolio-Vedant

Self-audit passed — every finding this report gathered is cited below.

Verdict: 4/10 — Est. 9-17 engineer-hours to acquisition-ready

The live_Portfolio-Vedant repository successfully installs dependencies via npm and runs tests, but contains significant security and stability risks including broken syntax in source code, hardcoded potential credentials, and 6 vulnerable dependencies. Remediation is estimated to require 13 engineer-hours (with a range of 9 to 17 hours).

Remediation Cost Estimate

Item	Hours	Basis
Upgrade 6 vulnerable dependencies	12	2h per package (research safe upgrade + apply + regression test)
Rotate 1 hardcoded credential(s) found in production code	1	1h per finding (rotate + remove from code + wire to secrets manager)

Total: 13 hours (range: 9-17h)

Heuristic estimate based on the stated per-item assumptions above, not a professional engineering quote. Presented as a range (9-17h) to avoid false precision. Does not include general code-quality improvements beyond the specific findings listed.

Risks

- **Hardcoded high-entropy secret detected in production file**
Secret scan flagged 1 'High-entropy string (possible secret)' finding in 'test.py' at line 3 ('in_test_dir': false).
- **Multiple unpinned dependencies contain known security vulnerabilities**
Dependency scan revealed 6 vulnerable packages out of 14 total unpinned dependencies in 'package.json': 'gsap' (1 vuln), 'react' (2 vulns), 'react-dom' (1 vuln), 'three' (1 vuln), 'postcss' (7 vulns), and 'vite' (22 vulns).
- **Syntax truncation in component source file causes broken React code**
Sampled file review of 'src/components/Artifacts.jsx' discovered the file is truncated mid-syntax ('maxWidth: 'min'), producing invalid React code.
- **Unconfigured ESLint hooks plugin and global scope pollution**
File reviews noted 'eslint.config.js' imports 'eslint-plugin-react-hooks' without enabling its rules, while 'src/App.jsx' attaches the Lenis instance directly to 'window.__lenis'.

Strengths

- **Dependencies install successfully and tests run**
Build/test evidence confirms 'install_ok': true and 'tests_ran': true for javascript/typescript (npm).
- **Optimized DOM updates and fallback protection in preloader component**

Sampled file review of 'src/components/Awakening.jsx' shows direct mutation of `textContent` on a DOM ref for 60fps counter performance, a 5.5-second safety fallback timeout, and explicit teardown logic.

- **Clean component cleanup and device-aware scroll optimizations**

Sampled file review of 'src/App.jsx' shows proper destruction of GSAP ticker callbacks, event listeners, and `Lenis` instances on unmount, alongside '(pointer: coarse)' media query checks for touch devices.

License

Project license: **not found**

Dependencies checked: 14, conflicts: 0, unknown license: 1

Ownership & Continuity Risk

1 contributor(s), top contributor: 100.0% of commits, last push: 53 days ago

Could Not Verify

- Specific test pass/fail breakdown or coverage metrics (test execution succeeded but 'test_summary' was empty).
- Containerized build and runtime behavior (no Dockerfile or compose file present; 'has_dockerfile': false).
- Project licensing compliance (no local LICENSE file was found).

Every claim above is backed by evidence in the full JSON report.